

ACCESS CONTROL POLICY

Document ID: ISP-AC-001 | Version 1.0

Effective Date: 12 March 2026

Classification: Internal

Approved by

Meera Khanna, Chief Information Security Officer

Electronic Approval Recorded: 12 March 2026

This sample has intentionally limited scope and authentication requirements so it can be used to test evidence extraction and cross-framework gap detection.

Document Control

Field	Value
Document Title	Access Control Policy
Document ID	ISP-AC-001
Version	1.0
Owner	Information Security
Policy Owner	Head - Information Security
Approver	Meera Khanna, Chief Information Security Officer
Approval Date	12 March 2026
Effective Date	12 March 2026
Review Frequency	Annual
Next Review Date	12 March 2027
Classification	Internal
Status	Approved and Published

Revision History

Version	Date	Author	Change Summary	Approval
1.0	12 Mar 2026	Information Security Team	Initial approved issue	CISO

1. Purpose

The purpose of this policy is to define requirements for granting, reviewing, using and revoking access to Asteron Systems Pvt. Ltd. information systems. Access shall be provided according to business need, least privilege and role-based access principles.

The policy is intended to reduce the risk of unauthorised access, privilege misuse, account compromise and inappropriate retention of access after an employee or contractor changes role or leaves the organisation.

2. Scope

This policy applies to employees, contractors, interns and authorised third parties who access Corporate IT systems managed by Asteron Systems Pvt. Ltd., including the corporate identity platform, email, collaboration tools, source-code repositories, endpoint management systems and internal business applications.

The policy applies to Corporate IT operations at the Bengaluru and Mumbai offices and to remote users connecting through the company-managed VPN. System owners may define stricter requirements for individual systems where required by contractual, customer or regulatory obligations.

Scope note: this version does not expressly identify or include a Cardholder Data Environment (CDE) or payment-processing infrastructure.

3. Access Control Principles

- Access is granted on the basis of a documented business requirement and approved role.
- Users receive the minimum privileges necessary to perform their assigned duties.
- Shared accounts are prohibited unless technically unavoidable and formally approved.
- Privileged access must be separated from normal day-to-day user access wherever technically feasible.
- Access rights are reviewed periodically and removed promptly when no longer required.
- Access decisions must be traceable to an approver and retained as evidence.

4. Roles and Responsibilities

The Information Security team owns this policy and monitors compliance. Human Resources notifies IT of joiners, movers and leavers. System Owners approve access appropriate to their systems. IT Operations provisions and removes access. Managers validate that access requested for their staff is necessary. Users are responsible for protecting their credentials and reporting suspected compromise immediately.

Privileged access requests require approval from both the user's manager and the applicable System Owner. Emergency access may be issued for a limited period and must be reviewed after use.

5. User Access Lifecycle

5.1 Joiners

New user access is created only after an approved onboarding request is received. The request must identify the user, department, manager, required systems, requested role and business justification. Default access is limited to standard collaboration and productivity services.

5.2 Movers

When a user changes department, role or project, the manager and relevant System Owners must review existing access. Access no longer required must be removed before new elevated access is granted where practical.

5.3 Leavers

Human Resources shall notify IT Operations of confirmed departures. Interactive access for involuntary leavers shall be disabled immediately at the time directed by HR. For planned departures, access shall be disabled no later than the end of the user's final working day. Privileged credentials, tokens and remote-access permissions shall be revoked as part of the offboarding checklist.

6. Authentication and Password Requirements

User authentication shall use centrally managed identity services wherever available. Passwords must not be shared, written in publicly visible locations or transmitted through unapproved channels.

- Minimum password length: 8 characters.
- Passwords must contain characters from at least three of the following groups: uppercase letters, lowercase letters, numbers and special characters.
- Default or vendor-supplied passwords must be changed before production use.
- Accounts must be locked or otherwise rate-limited after repeated failed authentication attempts.
- Password reset processes must verify the identity of the requestor before issuing or activating replacement credentials.

Where a system supports passphrases, users are encouraged to use longer unique passphrases. System Owners may configure stronger password settings for systems that process higher-risk information.

7. Multi-Factor Authentication

Multi-factor authentication (MFA) is mandatory for remote access through the corporate VPN and for administrative access to cloud management consoles where the platform supports MFA.

Standard internal user access to applications from the managed corporate network may use single-factor authentication where the application is integrated with the corporate identity provider and no elevated privileges are granted.

Current MFA requirement is therefore not universal across all access paths.

8. Privileged Access Management

- Privileged accounts must be assigned to named individuals and must not be used for routine email, browsing or office productivity.

- Administrative access requires documented approval and must be reviewed at least quarterly.
- Privileged access should be time-bound where the platform supports just-in-time access.
- Administrative actions must be logged where technically feasible.
- Break-glass accounts must be restricted, monitored and tested periodically.

9. Access Reviews

System Owners shall review user access at least quarterly for critical systems and at least annually for other in-scope Corporate IT systems. Reviews must identify inactive accounts, excessive privileges, access inconsistent with current job responsibilities and accounts belonging to departed users.

The review record must include the system reviewed, review date, population or account list, reviewer, decisions taken and evidence that identified removals were completed.

10. Remote Access

Remote access to the corporate network must use the approved VPN service and company-managed authentication. MFA is required for VPN access. Remote access from shared or public devices is prohibited unless specifically approved for an emergency and subject to compensating controls.

Users shall not bypass endpoint security controls or disable security software in order to obtain remote access.

11. Third-Party Access

Third-party access requires a named internal sponsor, documented business need, System Owner approval and a defined expiry or review date. Access must be limited to the systems necessary to deliver the contracted service. Third-party access shall be disabled when the engagement ends or when the sponsor confirms that access is no longer required.

12. Logging and Monitoring

Authentication events, failed logins and privileged activity should be logged for systems that support central logging. Information Security may review authentication logs when investigating suspected misuse, access anomalies or policy violations.

Log retention periods are defined by the Logging and Monitoring Standard and by system-specific requirements.

13. Exceptions

Any exception to this policy must be documented with the affected system, business justification, risk, compensating controls, owner and expiry date. Exceptions require approval from the Head of Information Security. Material exceptions may require CISO approval.

14. Compliance and Enforcement

Failure to comply with this policy may result in access suspension, corrective action or disciplinary action in accordance with company policy and applicable law. Information Security may request evidence of compliance from System Owners and may require remediation where controls are not implemented as expected.

15. Policy Review and Approval

This policy shall be reviewed at least annually, or earlier following a material security incident, significant technology change, regulatory change, or major change to the organisation's identity and access management environment.

The next scheduled review date is 12 March 2027. Changes require review by the Information Security team and approval by the Chief Information Security Officer before publication.

Approval Record

Role	Name	Decision	Date
Policy Owner	Arjun Rao - Head, Information Security	Recommended	10 Mar 2026
Approver	Meera Khanna - Chief Information Security Officer	Approved	12 Mar 2026

Electronic approval is recorded in the policy register. No handwritten signature is required for this electronically approved internal policy.

Appendix A - Related Records

- Joiner-Mover-Leaver Procedure (IAM-PR-002)
- Quarterly User Access Review Template (IAM-FM-004)
- Remote Access Standard (NET-STD-003)
- Logging and Monitoring Standard (SEC-STD-006)
- Information Security Exception Register (GRC-REG-005)